NORMA INTERNACIONAL

ISO/IEC 22301:2019

Seguridad y resiliencia — Continuidad del negocio sistemas de gestión — Requisitos

Número de referencia
ISO/IEC 22301:2019

© ISO 2019 – Derechos reservados

© ISO 2019

DOCUMENTO PROTEGIDO POR DERECHOS DE AUTOR

Reservados todos los derechos. A menos que se especifique lo contrario, o se requiera en el contexto de su implementación, ninguna parte de esta publicación puede ser reproducida o utilizada de otra manera en cualquier forma o por cualquier medio,electrónico o mecánico, incluyendo fotocopias o publicación en Internet o una intranet, sin previo aviso. Permiso escrito. El permiso se puede solicitar a ISO en la dirección a continuación o al organismo miembro de ISO en el país del solicitante.

ISO copyright office
CP 401 • Ch. de
Blandonnet 8C 1214
Vernier, Geneva
Phone: +41 22 74 01 11
Fax: +41 22 749 09 47
Email:
copyright@iso.org
Website:
www.iso.org
Publicado en Suiza

Contenido

Página

Prólogo **5**
Introducción **6**
1 Alcance **9**
2 Referencias normativas **9**
3 Términos y definiciones **9**
4 Contexto de la organización **18**
Comprensión de la organización y su contexto 18
Comprender las necesidades y expectativas de las partes interesadas 18
General 18
Requisitos legales y reglamentarios 18
Determinar el alcance del sistema de gestión de la continuidad del negocio 18
General 18
Alcance del BCMS 18
Sistema de gestión de continuidad del negocio 19
5 Liderazgo **19**
Liderazgo y compromiso 19
Política 19
La alta dirección debe establecer una política de continuidad del negocio que 19
La política de continuidad del negocio deberá 19
Funciones, responsabilidades y autoridades organizativas 20
6 Planificación **20**
Acciones para abordar riesgos y oportunidades 20
Objetivos de continuidad del negocio y planificación para alcanzarlos 20
Planificación de cambios en el BCMS 21
7 Soporte **21**
Recursos 21
Competencia 21
Conciencia 21
Comunicación 22
Información documentada 22
General 22
Creación y actualización 22
Control de información documentada 22
8 Operación **23**
Planificación y control operacional 23
Análisis de impacto del negocio y evaluación de riesgos 23
General 23
Análisis de Impacto del Negocio 23
Evaluación de riesgos 24
Estrategias y soluciones de continuidad del negocio 24
General 24
Identificación y selección de estrategias y soluciones 24
Requerimientos de recursos 24
Implementación de soluciones 25
Planes y procedimientos de continuidad del negocio 25
General 25
Estructura de respuesta 25
Advertencia y comunicación 26
Planes de continuidad del negocio 26
Recuperación 27
Programa de ejercicio 27

© ISO 2019 – Derechos reservados

Evaluación del desempeño **27**
Seguimiento, medición, análisis y evaluación 27
General 27
Evaluación de planes, procedimientos y capacidades de continuidad del negocio 28
Auditoría interna 28
La organización debe 28
Revisión de gestión 28
General 28
Entrada de revisión por la dirección 29
Resultados de la revisión por la dirección 29

9 Mejora **29**
No conformidad y acción correctiva 29
Mejora continua 30

Bibliografía **31**

Prólogo

ISO (la Organización Internacional de Normalización) es una federación mundial de organismos nacionales de normalización (organismos miembros de ISO). El trabajo de preparación de Normas Internacionales se realiza normalmente a través de los comités técnicos de ISO. Cada organismo miembro interesado en un tema para el cual se haya establecido un comité técnico tiene derecho a estar representado en ese comité. Las organizaciones internacionales, gubernamentales y no gubernamentales, en coordinación con ISO, también participan en el trabajo. ISO colabora estrechamente con la Comisión Electrotécnica Internacional (IEC) en todos los asuntos de normalización electrotécnica.

Los procedimientos utilizados para desarrollar este documento y aquellos previstos para su mantenimiento posterior se describen en las Directivas ISO / IEC, Parte 1. En particular, deben tenerse en cuenta los diferentes criterios de aprobación necesarios para los diferentes tipos de documentos ISO. Este documento fue redactado de acuerdo con las reglas editoriales de las Directivas ISO / IEC, Parte 2 (ver www.iso.org/directives).

Se llama la atención sobre la posibilidad de que algunos de los elementos de este documento puedan estar sujetos a derechos de patente. ISO no se hace responsable de identificar alguno o todos los derechos de patente. Los detalles de cualquier derecho de patente identificado durante el desarrollo del documento estarán en la Introducción y / o en la lista ISO de declaraciones de patentes recibidas (ver www.iso.org/patents).

Cualquier nombre comercial utilizado en este documento es información proporcionada para la conveniencia de los usuarios y no constituyen un respaldo.

Para obtener una explicación sobre la naturaleza voluntaria de las normas, el significado de los términos y expresiones específicos de ISO relacionados con la evaluación de la conformidad, así como información sobre la adhesión de ISO a los principios de la Organización Mundial del Comercio (OMC) en los Obstáculos Técnicos al Comercio (OTC), consulte el siguiente URL: www.iso.org/iso/foreword.html.

La Norma ISO 22301 fue preparada por el Comité Técnico ISO / TC 292, Seguridad y resiliencia. Cualquier comentario o pregunta sobre este documento debe dirigirse al organismo nacional de normalización del usuario.

La lista completa de estos órganos se puede encontrar en www.iso.org/members.html.

© ISO 2019 – Derechos reservados

Introducción

General

Este documento especifica la estructura y los requisitos para implementar y mantener un sistema de gestión de la continuidad del negocio (BCMS) eficaz.

Una organización debe desarrollar una continuidad del negocio que sea apropiada para la magnitud y el tipo de impacto que puede aceptar o no después de una interrupción. Los resultados de mantener un BCMS están determinados por los requisitos legales, reglamentarios, organizativos y de la industria de la organización, los productos y servicios proporcionados, los procesos empleados, el tamaño y la estructura de la organización y los requisitos de sus partes interesadas.

Un BCMS enfatiza la importancia de: comprender las necesidades de la organización y la necesidad de establecer políticas y objetivos de continuidad del negocio;

Operar y mantener procesos, capacidades y estructuras de respuesta para garantizar que la organización sobrevivirá a las interrupciones;

Monitorear y revisar el desempeño y la efectividad del BCMS;

mejora continua basada en medidas cualitativas y cuantitativas.

Un BCMS, como cualquier otro sistema de gestión, incluye los siguientes componentes:

a) una política;

b) personas competentes con responsabilidades definidas;

c) procesos de gestión relacionados con:

política;

planificación;

implementación y

operación; evaluación

del desempeño;

revisión de gestión;

mejora continua;

d) información documentada que respalde el control operativo y permita la evaluación del desempeño.

Beneficios del BCMS

El BCMS sirve para preparar, proporcionar y mantener controles y capacidades para gestionar la capacidad general para continuar operando durante las interrupciones. Para lograr esto, la organización:

a) desde una perspectiva empresarial:

— apoyando sus objetivos estratégicos;

— creando una ventaja competitiva;

— proteger y mejorar su reputación y credibilidad;

— contribuyendo a la resiliencia organizacional;

© ISO 2019 – Derechos reservados

b) desde una perspectiva financiera:

— hacer que los socios comerciales confíen en su éxito;

— reducir la exposición legal y financiera;

— reducción de los costos directos e indirectos de las interrupciones;

c) desde la perspectiva de las partes interesadas:

— proteger la vida, la propiedad y el medio ambiente;

— teniendo en cuenta las expectativas de las partes interesadas;

d) desde una perspectiva de procesos internos:

— mejorar su capacidad para mantenerse eficaz durante las interrupciones;

— Demostrar un control proactivo de los riesgos de forma eficaz y eficiente;

— abordar las vulnerabilidades operativas.

El modelo Planificar-Hacer-Verificar-Actuar (PDCA)

Este documento aplica el modelo "Planificar-Hacer-Verificar-Actuar" (PDCA) para planificar, establecer, implementar, operar, monitorear, revisar, mantener y mejorar continuamente la efectividad del BCMS de una organización.

Esto asegura un grado de coherencia con otras normas de sistemas de gestión, como ISO 9001 Sistemas de gestión de calidad, ISO 14001, Sistemas de gestión medioambiental, ISO/IEC 27001, Sistemas de gestión de seguridad de la información, ISO/IEC 20000-1, Tecnología de la información - Gestión de servicios, e ISO 28000, Especificación para sistemas de gestión de seguridad para la cadena de suministro, apoyando así la implementación y operación consistente e integrada con los sistemas de gestión relacionados.

Componentes de PDCA en este documento

En el modelo PDCA, las cláusulas 4 a 10 de este documento cubren los siguientes componentes.

La cláusula 4 es un componente del Plan. Introduce los requisitos necesarios para establecer el contexto del BCMS según se aplica a la organización, así como las necesidades, los requisitos y el alcance.

La cláusula 5 es un componente del Plan. Resume los requisitos específicos del papel de la alta dirección en el BCMS y cómo el liderazgo articula sus expectativas a la organización a través de una declaración de política.

La cláusula 6 es un componente del Plan. Describe los requisitos en lo que respecta al establecimiento de objetivos estratégicos y principios rectores para el BCMS en su conjunto.

La cláusula 7 es un componente del Plan. Apoya las operaciones del BCMS en lo que se refiere al establecimiento de la competencia y la comunicación de forma recurrente / según sea necesario con las partes interesadas, mientras documenta, controla, mantiene y retiene la información documentada requerida.

La cláusula 8 es un componente de Do. Define las necesidades de continuidad del negocio, determina cómo abordarlas y desarrolla los procedimientos para gestionar la organización durante una interrupción.

La cláusula 9 es un componente de revisión. Resume los requisitos necesarios para medir el desempeño de la continuidad del negocio, el cumplimiento de BCMS con este documento y la revisión de la dirección.

La cláusula 10 es un componente de la ley. Identifica y actúa en caso de no conformidad con BCMS y mejora mediante acciones correctivas.

© ISO 2019 – Derechos reservados

Contenido de este documento

Este documento cumple con los requisitos de ISO para los estándares del sistema de gestión. Estos requisitos incluyen una estructura de alto nivel, un texto básico idéntico y términos comunes con definiciones básicas, diseñados para beneficiar a los usuarios que implementan múltiples estándares de sistemas de gestión ISO.

Este documento no incluye requisitos específicos para otros sistemas de gestión, aunque sus elementos pueden alinearse o integrarse con los de otros sistemas de gestión.

Este documento contiene requisitos que una organización puede utilizar para implementar un BCMS y evaluar la conformidad. Una organización que desee demostrar la conformidad con este documento puede hacerlo de la siguiente manera:

Hacer una autodeterminación y auto declaración, o buscar la confirmación de su conformidad por parte de las partes interesadas en la organización, como clientes, o buscando la confirmación de su auto declaración por una parte externa a la organización, o buscando lacertificación / registro de su BCMS por una organización externa.

Las cláusulas 1 a 3 de este documento establecen el alcance, las referencias normativas y los términos y definiciones que se aplican al uso de este documento, mientras que las cláusulas 4 a 10 contienen los requisitos que se utilizarán para evaluar la conformidad con este documento.

En este documento, se utilizan las siguientes formas verbales:

a) "deberá" indica un requisito;

b) "debería" indica una recomendación;

c) "puede" indica un permiso;

d) "puede" indica una posibilidad o capacidad.

La información marcada como "NOTA" es una guía para comprender o aclarar el requisito asociado. Las "Notas a la entrada" utilizadas en la Cláusula 3 proporcionan información adicional que complementa los datos terminológicos y pueden contener disposiciones relacionadas con el uso de un término.

© ISO 2019 – Derechos reservados

Seguridad y resiliencia — Continuidad del negocio sistemas de gestión — Requisitos

1 Alcance

Este documento especifica los requisitos para planificar, establecer, implementar, operar, monitorear, revisar, mantener y mejorar continuamente un sistema de gestión para proteger contra, reducir la probabilidad de ocurrencia, prepararse, responder y recuperarse de interrupciones cuando surjan.

Los requisitos especificados en este documento son genéricos y están destinados a ser aplicables a todas las organizaciones, o partes de estas, independientemente del tipo, tamaño y naturaleza de la organización. El alcance de la aplicación de estos requisitos depende del entorno operativo y la complejidad de la organización.

Este documento es aplicable a todos los tipos y tamaños de organizaciones que:

a) implementar, mantener y mejorar un BCMS;

b) buscar asegurar la conformidad con la política de continuidad del negocio establecida;

c) necesitan la capacidad de continuar la entrega de productos y servicios a una capacidad predefinida aceptable durante una interrupción;

d) buscar mejorar su resiliencia a través de la aplicación efectiva del BCMS.

Este documento se puede utilizar para evaluar la capacidad de una organización para satisfacer sus propias necesidades de continuidad del negocio y obligaciones.

2 Referencias normativas

No hay referencias normativas en este documento.

3 Términos y definiciones

Para los propósitos de este documento, se aplican los siguientes términos y definiciones.

ISO e IEC mantienen bases de datos terminológicas para su uso en la estandarización en las siguientes direcciones:

— Plataforma de navegación en línea ISO: disponible en http://www.iso.org/obp

— IEC Electro pedía: Disponible en http://www.electropedia.org

3.1
Actividad
Un conjunto de una o más tareas con un resultado definido

[FUENTE: ISO 22300:2018, 3.1, modificado. Nota a la entrada eliminada.]

3.2
Auditoria
Proceso sistemático, independiente y documentado (3.40) para obtener evidencia de auditoría y evaluarla objetivamente para determinar en qué medida se cumplen los criterios de auditoría.

Nota 1 a la entrada: Los elementos fundamentales de una auditoría incluyen la determinación de la conformidad (3.8) de un objeto (3.29) de acuerdo con un procedimiento (3.39) llevado a cabo por personal (3.35) que no es

© ISO 2019 – Derechos reservados

responsable del objeto auditado.

Nota 2 a la entrada: una auditoría puede ser una auditoría interna (primera parte) o una auditoría externa (segunda o tercera parte), y puede ser una auditoría combinada (combinando dos o más disciplinas).
Nota 3 a la **entrada**: La organización o una parte externa en su nombre realiza una auditoría interna. La auditoría interna puede ser para revisión de la dirección (3.24) (3.47) y otros propósitos internos, y puede constituir la base para la declaración de conformidad de una organización. La independencia puede demostrarse por la ausencia de responsabilidad por la actividad (3.1) que se audita.
Nota 4 a la entrada: Las auditorías externas incluyen las que generalmente se denominan auditorías de segunda y tercera parte. Las auditorías de segunda parte son realizadas por partes que tienen un interés en la organización, como los clientes, o por otras personas en su nombre. Las auditorías de terceros son realizadas por organizaciones de auditoría externas e independientes, como las que brindan certificación / registro de conformidad o agencias gubernamentales.
Nota 5 a la entrada: a la entrada "Evidencia de auditoría" y "criterios de auditoría" se definen en ISO 19011.

[FUENTE: ISO 22300: 2018, 3.13, modificada. Notas a las entradas 5, 6 y 8 eliminadas.]

3.3
Continuidad del negocio
Capacidad de una organización (3.31) para continuar la entrega de productos y servicios (3.41) dentro delos límites aceptables marcos de tiempo a la capacidad predefinida relacionados con una interrupción (3.12)

[FUENTE: ISO 22300: 2018, 3.24, modificado.]

3.4
Sistema de gestión de continuidad del negocio
BCMS
Sistema de gestión (3.25) de *continuidad del negocio* (3.3)

Nota 1 a la entrada: El sistema de gestión incluye estructura organizativa, políticas, planificación (3.36) actividades (3.1), responsabilidades, procedimientos (3.39), procesos (3.40) y recursos.

[FUENTE: ISO 22300:2018, 3.26, modificado]

3.5
Plan de continuidad del negocio
Información documentada (3.13) que guía a una organización (3.31) para responder a una interrupción (3.12) y reanudar, recuperar y restaurar la entrega de productos y servicios de acuerdo con sus objetivos decontinuidad del negocio

[FUENTE: ISO 22300:2018, 3.27, modificado. Nota 1 a la entrada eliminada.]

3.6
Análisis de impacto del negocio
Proceso (3.40) de análisis del impacto (3.18) de una interrupción (3.12) en la organización (3.31)

Nota 1 a la entrada: El resultado es una declaración y una justificación de los requisitos de continuidad del negocio (3.3) (3.45).

[FUENTE: ISO 22300:2018, 3.29, modificada. Nota 1 a la entrada eliminada.]

3.7
Competencia
Capacidad de aplicar conocimientos y habilidades para lograr el objetivo deseado

[FUENTE: ISO 22300:2018, 3.44.]

3.8
Conformidad
Cumplimiento de un requisito (3.45)

© ISO 2019 – Derechos reservados

[FUENTE: ISO 22300:2018, 3.45.]

3.9
Consecuencia
Resultado de un evento (3.16) que afecta a los objetivos (3.30)

Note 1 a la entrada: Una consecuencia puede ser cierta o incierta y puede tener efectos directos o indirectos positivos o negativos sobre los objetivos.

Note 2 a la entrada: Consecuencias pueden ser expresadas cualitativa o cuantitativamente.
Note 3 a la entrada: Cualquier consecuencia puede escalar a través de efectos acumulativos.

[FUENTE: ISO 31000:2018, 3.6.**]**

3.10
Mejora continua
Actividad recurrente (3.1) para mejorar el rendimiento (3.33)

[FUENTE: ISO 22300:2018, 3.48.]

3.11
Acción correctiva
Acción para eliminar la causa de una no conformidad (3.28) y para prevenir la recurrencia

Nota 1 a la entrada: En el caso de otros resultados indeseables, es necesario actuar para minimizar o eliminar las causas y reducir el impacto (3.18) o prevenir la recurrencia. Tales acciones quedan fuera del concepto de "acción correctiva" en el sentido de esta definición.

[FUENTE: ISO 22300:2018, 3.54.]

3.12
Ruptura
incidente (3.19), ya sea anticipado o no anticipado, que cause una desviación negativa no planificada de la entrega esperada de productos y servicios (3.41) de acuerdo con los objetivos (3.31) de una organización (3.30)

[FUENTE: ISO 22300:2018, 3.70, modificado.]

3.13
Información documentada
Información (3.20) requiere ser controlado y mantenido por una organización (3.31) y el medio en el que está contenido

Nota 1 a la entrada: La información documentada puede estar en cualquier formato y en cualquier medio, y de cualquier fuente. Nota 2 a la entrada: La información documentada puede referirse a: el sistema de gestión (3.25), incluidos los procesos relacionados (3.40); información creada para que la organización funcione (documentación); evidencia de los resultados obtenidos (registros (3.43)).

[FUENTE: ISO 22300:2018, 3.72.]

3.14
Eficacia
Medida en que se realizan las actividades planificadas (3.1) y se logran los resultados planificados

[FUENTE: ISO 22300:2018, 3.76.]

3.15
Emergencia
Suceso o evento repentino, urgente y generalmente inesperado (3.16) que requiere una acción inmediata.

Nota 1 a la entrada: Una emergencia suele ser una interrupción (3.12) o una condición que a menudo se puede anticipar o preparar.

© ISO 2019 – Derechos reservados

[FUENTE: ISO 22300:2018, 3.77.]

3.16
Evento
Ocurrencia o cambio de un conjunto particular de circunstancias

Nota 1 a la entrada: Un evento puede ser una o más ocurrencias y puede tener varias causas y varias consecuencias (3.9).
Nota 2 a la entrada: Un evento también puede ser algo que se espera que no suceda, o algo que no se espera que suceda.
Nota 3 a la entrada: un evento puede ser una fuente de riesgo.

[FUENTE: ISO 31000:2018, 3.5.]

3.17
Ejercicio
Proceso (3.40) para capacitar, evaluar, practicar y mejorar el desempeño (3.33) en una organización (3.31)

Nota 1 a la entrada: Los ejercicios se pueden utilizar para validar políticas, planes, procedimientos (3.39), capacitación (3.54), equipos y acuerdos entre organizaciones; aclarar y capacitar al personal (3.35) en roles y responsabilidades; mejorar la coordinación y las comunicaciones entre organizaciones; identificar brechas en los recursos; mejorar el desempeño individual e identificar oportunidades de mejora; y una oportunidad controlada para practicar la improvisación. Un ejercicio no necesita la expectativa de aprobar o reprobar.
Nota 2 a la entrada: consulte también la prueba (3.52).

[FUENTE: ISO 22300:2018, 3.83, modificado, agregado "Un ejercicio no necesita una expectativa de aprobación o reprobación.']

3.18
Impacto
Resultado de una interrupción (3.12) que afecta a los objetivos (3.30)

[FUENTE: ISO 22300:2018, 3.107, modificado.]

3.19
Incidente
Evento (3.16) que puede ser, o podría llevar a, una interrupción (3.12), pérdida, emergencia (3.15) o crisis.

[FUENTE: ISO 22300:2018, 3.111, modificada.]

3.20
Información
Datos procesados, organizados y correlacionados para producir significado

[FUENTE: ISO 22300:2018, 3.116.]

3.21
Parte interesada
Persona u organización (3.31) que puede afectar, verse afectada o percibirse a sí misma como afectada por una decisión o actividad (3.1)

EJEMPLO Clientes, propietarios, personal (3.35), proveedores, banqueros, reguladores, sindicatos, socios o sociedad que puede incluir competidores o grupos de presión opuestos.

Nota 1 a la entrada: un tomador de decisiones puede ser una parte interesada.
Nota 2 a la entrada: Las comunidades afectadas y las poblaciones locales se consideran partes interesadas externas.

[FUENTE: ISO 22300:2018, 3.124, modificado. Se ha modificado el ejemplo. Se ha eliminado la nota 3 a la entrada.]

© ISO 2019 – Derechos reservados

3.22
Auditoría interna
Auditoría (3.2) realizada por, o en nombre de, una organización (3.31) misma para la revisión (3.47) de la dirección (3.24) y otros fines internos, y que puede formar la base para la auto declaración de conformidad de una organización (3.8).

Nota 1 a la entrada: En muchos casos, particularmente en organizaciones más pequeñas, la independencia puede demostrarse por la ausencia de responsabilidad por la actividad (3.1) que se audita.

[FUENTE: ISO 22300:2018, 3.126.]

3.23
Probabilidad
Posibilidad de que ocurra algo

Nota 1 a la entrada: En la terminología de gestión de riesgos (3.50), la palabra "probabilidad" se utiliza para referirse a la posibilidad de que algo suceda, ya sea definida, medida o determinada objetiva o subjetivamente, cualitativa o cuantitativamente, y descrita utilizando términos generales o matemáticos. (como una probabilidad o una frecuencia durante un período de tiempo determinado).
Nota 2 a la entrada: El término inglés "verosimilitud" no tiene un equivalente directo en algunos idiomas; en cambio, a menudo se utiliza el equivalente del término "probabilidad". Sin embargo, en inglés, "probabilidad" a menudo se interpreta de manera estricta como un término matemático. Por lo tanto, en la terminología de la gestión de riesgos, "verosimilitud" se utiliza con la intención de que tenga la misma interpretación amplia que tiene el término "probabilidad" en muchos idiomas además del inglés.

[FUENTE: ISO 31000:2018, 3.7.]

3.24
Gestión
Actividades coordinadas (3.1) para dirigir y controlar una organización (3.31)

[FUENTE: ISO 22300:2018, 3.135.]

3.25
Sistema gestión
Conjunto de elementos interrelacionados o que interactúan de una organización (3.31) para establecer políticas (3.37) objetivos (3.30) y procesos (3.40) para lograr esos objetivos

Nota 1 a la entrada: Un sistema de gestión puede abordar una sola disciplina o varias disciplinas.
Nota 2 a la entrada: Los elementos del sistema incluyen la estructura de la organización, roles y responsabilidades, planificación (3.36) y funcionamiento.
Nota 3 a la entrada: El alcance de un sistema de gestión puede incluir la totalidad de la organización, funciones específicas e identificadas de la organización, secciones específicas e identificadas de la organización, o una o más funciones en un grupo de organizaciones.

[FUENTE: ISO 22300:2018, 3.137. Nota 3 modificada para incluir "puede" en lugar de "puede".]

3.26
Medición
Proceso (3.40) para determinar un valor

[FUENTE: ISO 22300:2018, 3.143.]

3.27
Monitoreo
Determinar el estado de un sistema, un proceso (3.40) o una actividad (3.1)

[FUENTE: ISO 22300:2018, 3.147, modificado.]

3.28
No conformidad

© ISO 2019 – Derechos reservados

Incumplimiento de un requisito (3.45)

3.29
Objeto
Entidad única y distinta que puede ser identificada

[FUENTE: ISO 22300:2018, 3.151.]

3.30
Objetivo
Resultado a alcanzar

Nota 1 a la entrada: un objetivo puede ser estratégico, táctico u operativo.
Nota 2 a la entrada: Los objetivos pueden relacionarse con diferentes disciplinas (como los objetivos financieros, de salud y seguridad y medioambientales, y pueden aplicarse a diferentes niveles (como estratégico, de toda la organización, proyecto, producto y proceso (3.40)).
Nota 3 a la entrada: Un objetivo puede expresarse de otras formas, p. Ej. como un resultado previsto, un propósito, un criterio operativo, o mediante el uso de otras palabras con un significado similar (por ejemplo, objetivo, meta o meta).
Nota 4 a la entrada: En el contexto de los sistemas de gestión de la continuidad del negocio (3.4), la organización establece los objetivos de continuidad del negocio, de conformidad con la política de continuidad del negocio (3.37), para lograr resultados específicos.

[FUENTE: ISO 22300:2018, 3.30. La nota 4 a la entrada ha sido modificada para reflejar BCMS.]

3.31
Organización
Persona o grupo de personas que tiene sus propias funciones con responsabilidades, autoridades y relaciones para lograr sus objetivos (3.30)

Nota 1 a la entrada: a la entrada: El concepto de organización incluye, entre otros, comerciante individual, empresa, corporación, firma, empresa, autoridad, sociedad, organización benéfica o institución, o parte o combinación de estas, ya sea que estén incorporadas o no. , público o privado.
Nota 2 a la entrada: Para organizaciones con más de una unidad operativa, una sola unidad operativa se puede definir como organización.

[FUENTE: ISO 22300:2018, 3.31.]

3.32
Subcontratar
Hacer un arreglo en el que una organización externa (3.31) realiza parte de la función o proceso de una organización (3.40)

Nota 1 a la entrada: a la entrada: Una organización externa está fuera del alcance del sistema de gestión (3.25), aunque la función o proceso subcontratado está dentro del alcance.

[FUENTE: ISO 22300:2018, 3.160.]

3.33
Rendimiento
Resultado medible

Nota 1 a la entrada: El desempeño puede relacionarse con hallazgos cuantitativos o cualitativos.
Nota 2 a la entrada: El desempeño puede relacionarse con la gestión (3.24) de actividades (3.1), procesos (3.40), productos y servicios (3.41), sistemas u organizaciones (3.31).

[FUENTE: ISO 22300:2018, 3.157, modificado-referencia a "productos y servicios".]

3.34
Evaluación de rendimiento

Proceso (3.40) para determinar resultados medibles contra los criterios establecidos

[FUENTE: ISO 22300: 2018, 3.168, modificada, agregada "contra los criterios establecidos", "para determinar, en lugar de" para determinar ".]

3.35
Personal
Personas que trabajan para y bajo el control de la organización (3.31)

Nota 1 a la entrada: El concepto de personal incluye, entre otros, empleados, personal a tiempo parcial y personal de la agencia.

[FUENTE: ISO 22300: 2018, 3.169.]

3.36
Planificación
Parte de la gestión (3.24) centrada en establecer objetivos de continuidad del negocio (3.3) (3.30) y especificar los procesos operativos necesarios (3.30) y los recursos relacionados para cumplir con los objetivos de continuidad del negocio

[FUENTE: ISO 22300: 2018, 3.170, modificada para reflejar la "continuidad del negocio".]

3.37
Política
Intenciones y dirección de una organización (3.31), expresadas formalmente por su alta dirección (3.53)

[FUENTE: ISO 22300: 2018, 3.171, modificada para incluir una coma].

3.38
Actividad priorizada
Actividad (3.1) a la que se le da urgencia con el fin de evitar impactos inaceptables para el negocio durante una disrupción (3.12)

[FUENTE: ISO 22300: 2018, 3.176, modificado.]

3.39
Procedimiento
Forma específica de llevar a cabo una actividad (3.1) o un proceso (3.40)

Nota 1 a la entrada: Los procedimientos pueden estar documentados o no.
Nota 2 a la entrada: Cuando un procedimiento está documentado, el término "procedimiento escrito" o "procedimiento documentado" se utiliza con frecuencia. El documento que contiene un procedimiento puede denominarse "documento de procedimiento".

[FUENTE: ISO 22300: 2018, 3.179.]

3.40
Proceso
Conjunto de actividades interrelacionadas o que interactúan (3.1) que transforma las entradas en salidas

[FUENTE: ISO 22300: 2018, 3.180, modificado.]

3.41
Producto o servicio
Producto o resultado proporcionado por una organización (3.31) a las partes interesadas (3.21)
EJEMPLO Artículos manufacturados, seguro de automóvil, enfermería comunitaria
Nota 1 a la entrada:
[FUENTE: ISO 22300: 2018, 3.181, modificado.]
3.42

Protección
Medidas que protegen y permiten a una organización (3.31) prevenir o reducir el impacto (3.18) de una interrupción potencial (3.12)

[FUENTE: ISO 22300: 2018, 3.182.]

3.43
Registro
Documento que indica los resultados obtenidos o que proporciona evidencia de las actividades (3.1) realizadas.

[FUENTE: ISO 22300: 2018, 3.186.]

3.44
Recuperación
Restauración y mejora, cuando corresponda, de las operaciones, instalaciones, medios de vida o condiciones de vida de las organizaciones afectadas (3.31), incluidos los esfuerzos para reducir los factores de riesgo (3.48)

[FUENTE: ISO 22300: 2018, 3.187.]

3.45
Requisito
Necesidad o expectativa que se declara, generalmente implícita u obligatoria

Nota 1 a la entrada: "Generalmente implícito" significa que es costumbre o práctica común para la organización (3.31) y partes interesadas (3.21) que la necesidad o expectativa bajo consideración está implícita.
Nota 2 a la entrada: Un requisito especificado es aquel que se establece, por ejemplo, en la información documentada (3.13).

[FUENTE: ISO 22300: 2018, 3.190.]

3.46
Resiliencia
Capacidad para absorber y adaptarse en un entorno cambiante

[FUENTE: ISO 22300: 2018, 3.192.]

3.47
Revisión
Actividad (3.1) realizada para determinar la idoneidad, adecuación y eficacia (3.14) del sistema de gestión (3.25) y sus elementos componentes para lograr los objetivos establecidos (3.30)

[FUENTE: ISO 22300: 2018, 3.197.]

3.48
Riesgo
Efecto de la incertidumbre sobre los objetivos (3.30)

Nota 1 a la entrada: Un efecto es una desviación del esperado: puede ser positivo, negativo o ambos, y puede abordar, crear o dar lugar a oportunidades y amenazas.
Nota 2 a la entrada: Los objetivos pueden tener diferentes aspectos, categorías y categorías y se pueden aplicar en niveles diferentes.
Nota 3 a la entrada: El riesgo generalmente se expresa en términos de fuentes de riesgo, eventos potenciales (3.16), sus consecuencias (3.9) y su probabilidad (3.23).
[FUENTE: ISO 31000: 2018, 3.1]
3.49
Evaluación de riesgos

Proceso general (3.40) de identificación de riesgos, análisis de riesgos y evaluación de riesgos
Nota 1 a la entrada: La evaluación de riesgos se describe en detalle en ISO 31000: 2018.

[FUENTE: ISO 22300: 2018, 3.203, modificado - La nota 1 a la entrada ha sido modificada.]

3.50
Gestión de riesgos
Actividades coordinadas (3.1) para dirigir y controlar una organización (3.31) con respecto al riesgo

[FUENTE: ISO 31000: 2018, 3.2]

3.51
Cadena de suministro
Relación bidireccional de organizaciones (3.31), personas, procesos (3.40), logística, información (3.20), tecnología y recursos involucrados en las actividades (3.1) y la creación de valor a partir del abastecimiento de materiales a través de la entrega de productos y servicios (3.41)

Nota 1 a la entrada: La cadena de suministro puede incluir proveedores, subcontratistas, instalaciones de fabricación, logística, proveedores, centros de distribución interna, distribuidores, mayoristas y otras entidades que conducen al usuario final.

[FUENTE: ISO 22300: 2018, 3.251, modificado a "productos y servicios"]

3.52
Prueba
Tipo de ejercicio único y particular (3.17) que incorpora la expectativa de un elemento de aprobación o reprobación dentro de la meta u objetivos (3.30) del ejercicio que se está planificando.

Nota 1 a la entrada: Los términos "prueba" y "prueba" no son lo mismo que "ejercicio" y "ejercicio".

[FUENTE: ISO 22300: 2018, 3.257.]

3.53
Alta gerencia
Persona o grupo de personas que dirige y controla una organización (3.31) al más alto nivel.

Nota 1 a la entrada: La alta dirección tiene el poder de delegar autoridad y proporcionar recursos dentro de la organización.
Nota 2 a la entrada: Si el alcance del sistema de gestión (3.25) cubre solo una parte de una organización, entonces arriba gestión se refiere a aquellos que dirigen y controlan esa parte de la organización.

[FUENTE: ISO 22300: 2018, 3.263, modificada. Se han eliminado las notas 3, 4 y 5 de la entrada.]

3.54
Capacitación
Actividades (3.1) diseñadas para facilitar el aprendizaje y desarrollo de conocimientos, habilidades y habilidades, y para mejorar el desempeño (3.33) de tareas o roles específicos

[FUENTE: ISO 22300: 2018, 3.265.]

3.55
Verificación
Confirmación, mediante la aportación de pruebas, de que se han cumplido los requisitos especificados(3.45)
[FUENTE: ISO 22300: 2018, 3.272.]

3.56
Ambiente de trabajo

© ISO 2019 – Derechos reservados

Conjunto de condiciones bajo las cuales se realiza el trabajo

Nota 1 a la entrada: Las condiciones incluyen factores físicos, sociales, psicológicos y ambientales (como temperatura, esquemas de reconocimiento, ergonomía y composición atmosférica).

[FUENTE: ISO 22300:2018, 3.276.]

4 Contexto de la organización

4.1 Comprensión de la organización y su contexto.

La organización debe determinar los problemas externos e internos que sean relevantes para su propósito y que afecten su capacidad para lograr los resultados previstos de su BCMS

NOTA: Estos problemas estarán influenciados por los objetivos generales de la organización, sus productos y servicios y la cantidad y tipo de riesgo que puede o no tomar.

4.2 Comprender las necesidades y expectativas de las partes interesadas

4.2.1 General

Al establecer su BCMS, la organización debe determinar:

a) las partes interesadas que sean relevantes para el BCMS;

b) los requisitos de estos interesados.

4.2.2 Requisitos legales y reglamentarios

La organización debe:

a) implementar y mantener un proceso para identificar, tener acceso y evaluar los requisitos legales y regulatorios aplicables relacionados con la continuidad de sus productos y servicios, procesos, actividades y recursos, así como los intereses de las partes interesadas relevantes;

b) asegurarse de que estos requisitos legales, reglamentarios y de otro tipo aplicables se tengan en cuenta en implementar y mantener su BCMS;

c) documentar esta información y mantenerla actualizada.

4.3 Determinar el alcance del sistema de gestión de la continuidad del negocio.

4.3.1 General

La organización debe determinar los límites y la aplicabilidad del BCMS para establecer su alcance.
Al determinar este alcance, la organización debe considerar:

a) las cuestiones externas e internas mencionadas en 4.1;

b) los requisitos mencionados en 4.2.

El alcance debe estar disponible como información documentada.

4.3.2 Alcance del BCMS

La organización debe:

a) considerar su misión, metas y obligaciones internas y externas;

© ISO 2019 – Derechos reservados

b) establecer las partes de la organización que se incluirán en el BCMS, teniendo en cuenta su (s) ubicación (es), tamaño, naturaleza y complejidad;

c) identificar los productos y servicios y sus procesos, actividades y recursos relacionados que se incluido en el BCMS;

d) tener en cuenta las necesidades de las partes interesadas.

Al definir el alcance, la organización debe documentar y explicar las exclusiones; Cualquiera de dichas exclusiones no afectará la capacidad y responsabilidad de la organización para proporcionar continuidad comercial, según lo determine el análisis de impacto comercial o la evaluación de riesgos y los requisitos legales o reglamentarios aplicables.

4.4 Sistema de gestión de continuidad del negocio

La organización debe establecer, implementar, mantener y mejorar continuamente un BCMS, incluidos los procesos necesarios y sus interacciones, de acuerdo con los requisitos de este documento.

5 Liderazgo

5.1 Liderazgo y compromiso

La alta dirección debe demostrar liderazgo y compromiso con respecto al BCMS al:

a) asegurar que se establezcan la política de continuidad del negocio y los objetivos de continuidad del negocio y son compatibles con la dirección estratégica de la organización;

b) asegurar la integración de los requisitos del BCMS en los procesos comerciales de la organización;

c) asegurar que los recursos necesarios para el BCMS estén disponibles;

d) comunicar la importancia de una continuidad comercial efectiva y cumplir con los requisitos del BCMS;

e) asegurar que el BCMS logre los resultados previstos;

f) dirigir y apoyar a las personas para que contribuyan a la eficacia del BCMS;

g) apoyar otros roles de gestión relevantes para demostrar su liderazgo y compromiso como se aplica a sus áreas de responsabilidad;

h) promover la mejora continua.

NOTA: La referencia a “negocios” en este documento puede interpretarse de manera amplia en el sentido de aquellas actividades que son fundamentales para los propósitos de la existencia de la organización.

5.2 Política

5.2.1 La alta dirección debe establecer una política de continuidad del negocio que:

a) es apropiado para el propósito de la organización;

b) proporciona un marco para establecer los objetivos de continuidad del negocio;

c) incluye el compromiso de satisfacer los requisitos aplicables;

d) incluye un compromiso con la mejora continua del BCMS.

5.2.2 La política de continuidad del negocio deberá:

a) estar disponible como información documentada;

© ISO 2019 – Derechos reservados

b) comunicarse dentro de la organización;

c) estar disponible para las partes interesadas, según corresponda.

5.3 Funciones, responsabilidades y autoridades organizativas

La alta dirección debe asegurarse de que las responsabilidades y autoridades para los roles relevantes se asignen y se comuniquen dentro de la organización.

La alta dirección debe asignar la responsabilidad y autoridad para:

a) asegurarse de que el BCMS cumpla con los requisitos de este documento;

b) informar sobre el desempeño del BCMS a la alta dirección.

6 Planificación

6.1 Acciones para abordar riesgos y oportunidades

Al planificar el BCMS, la organización debe considerar las cuestiones a las que se hace referencia en 4.1 y los requisitos mencionados en 4.2 y determinar los riesgos y oportunidades que deben abordarse para:

a) dar seguridad de que el sistema de gestión puede lograr los resultados previstos;

b) prevenir o reducir efectos no deseados;

c) lograr una mejora continua.

La organización debe planificar:

a) acciones para abordar estos riesgos y oportunidades,

b) cómo:

   1) integrar e implementar las acciones en sus procesos BCMS (ver 8.1),

   2) evaluar la efectividad de estas acciones (ver 9.1).

NOTA: los riesgos y oportunidades en esta sub-cláusula se relacionan con la efectividad del sistema de gestión. Riesgos relacionados con la interrupción del negocio se tratan en 8.2

6.2 Objetivos de continuidad del negocio y planificación para alcanzarlos.

6.2.1 La organización debe establecer objetivos de continuidad del negocio en las funciones y niveles relevantes.

Los objetivos de continuidad del negocio deberán:

a) ser coherente con la política de continuidad del negocio;

b) ser medible (si es posible);

c) tener en cuenta los requisitos aplicables;

d) ser monitoreado;

e) ser comunicada;

f) Actualizarse según corresponda.

La organización debe conservar información documentada sobre los objetivos de continuidad del negocio.

© ISO 2019 – Derechos reservados

6.2.2 Al planificar cómo lograr sus objetivos de continuidad del negocio, la organización debe determinar:

a) qué se hará;

b) qué recursos se requerirán;

c) quién será responsable;

d) cuando se completará;

e) cómo se evaluarán los resultados.

6.3 Planificación de cambios al BCMS

Cuando la organización determina la necesidad de cambios en el BCMS, incluidos los identificados en cláusula 10 mejora, los cambios se llevarán a cabo de manera planificada. La organización debe considerar:

a) el propósito de los cambios y sus posibles consecuencias;

b) la integridad del BCMS;

c) la disponibilidad de recursos;

d) la asignación o reasignación de responsabilidades y autoridades.

7 Soporte

7.1 Recursos

La organización debe determinar y proporcionar los recursos necesarios para el establecimiento, implementación, mantenimiento y mejora continua del BCMS.

7.2 Competencia

La organización debe:

a) determinar la competencia necesaria de la (s) persona (s) que realizan el trabajo bajo su control que afecta su desempeño en la continuidad del negocio;

b) asegurarse de que estas personas sean competentes sobre la base de una educación, formación o experiencia;

c) en su caso, tomar acciones para adquirir la competencia necesaria y evaluar la efectividad de las acciones tomadas;

d) conservar la información documentada adecuada como prueba de competencia.

NOTA: Las acciones aplicables pueden incluir, por ejemplo: la provisión de capacitación, la tutoría o la reasignación de personas actualmente empleadas; o la contratación o contratación de persona

7.3 Conciencia

Las personas que realicen trabajos bajo el control de la organización deberán conocer:

a) la política de continuidad del negocio;

b) su contribución a la eficacia del BCMS, incluidos los beneficios de un mejor desempeño en la continuidad del negocio;

c) las implicaciones de no cumplir con los requisitos del BCMS;

d) su propio rol y responsabilidades antes, durante y después de las interrupciones.

© ISO 2019 – Derechos reservados

7.4 Comunicación

La organización debe determinar las comunicaciones internas y externas relevantes para el BCMS, incluso:

a) sobre lo que comunicará;

b) cuando comunicarse;

c) con quién comunicarse;

d) cómo comunicarse;

e) quién se comunicará.

7.5 Información documentada

7.5.1 General

El BCMS de la organización debe incluir:

a) información documentada requerida por este documento;

b) información documentada determinada por la organización como necesaria para la eficacia del BCMS.

NOTA: El alcance de la información documentada para un BCMS puede diferir de una organización a otra debido a: el tamaño de la organización y su tipo de productos y servicios, procesos, actividades y recursos; la complejidad de los procesos y sus interacciones; la competencia de las personas.

7.5.2 Creación y actualización

Al crear y actualizar información documentada, la organización debe asegurarse de que sea apropiado:

a) identificación y descripción (por ejemplo, título, fecha, autor o número de referencia);

b) formato (por ejemplo, idioma, versión de software, gráficos) y medios (por ejemplo, papel, electrónico),

c) revisión y aprobación de idoneidad y adecuación

7.5.3 Control de información documentada

7.5.3.1 La información documentada requerida por el BCMS y por este documento se controlará para

garantizar:

a) está disponible y es adecuado para su uso, donde y cuando se necesite;

b) está adecuadamente protegido (por ejemplo, contra la pérdida de confidencialidad, uso indebido o pérdida de integridad).

7.5.3.2 Para el control de la información documentada, la organización debe abordar las siguientes actividades, según corresponda:

a) distribución, acceso, recuperación y uso;

b) almacenamiento y conservación, incluida la preservación de la legibilidad;

c) control de cambios (por ejemplo, control de versiones);

d) retención y disposición.

La información documentada de origen externo que la organización determine que es necesaria para la planificación y operación del BCMS deberá identificarse, según corresponda, y controlarse.

NOTA El acceso puede implicar una decisión con respecto al permiso para ver solo la información documentada, o el permiso y la autoridad para ver y cambiar la información documentada.

© ISO 2019 – Derechos reservados

8 Operación

8.1. Planificación y control operacional

La organización debe planificar, implementar y controlar los procesos necesarios para cumplir con los requisitos e implementar las acciones determinadas en 6.1, mediante:

a) establecer criterios para los procesos;

b) implementar el control de los procesos de acuerdo con los criterios;

c) mantener la información documentada en la medida necesaria para tener confianza en que los procesos se han llevado a cabo según lo previsto.

La organización debe controlar los cambios planificados y revisar las consecuencias de los cambios no deseados, tomando medidas para mitigar cualquier efecto adverso, según sea necesario.

La organización debe asegurarse de que los procesos subcontratados y la cadena de suministro estén controlados.

8.2 Análisis de impacto del negocio y evaluación de riesgos

8.2.1 General

La organización debe implementar y mantener un proceso para analizar el impacto comercial y evaluar los riesgos de interrupción que establezca el contexto, defina criterios y evalúe el impacto potencial de una interrupción.

NOTA: La organización determina el orden en el que se realizan el análisis de impacto empresarial y la evaluación de riesgos realizados.

8.2.2 Análisis de Impacto del Negocio

La organización debe implementar y mantener un proceso para determinar las prioridades y requisitos de continuidad del negocio que:

a) define categorías de impacto y criterios relevantes para el contexto de la organización;

b) utiliza estas categorías y criterios de impacto para medir el impacto;

c) identifica actividades que apoyan la provisión de productos y servicios;

d) analiza los impactos a lo largo del tiempo resultantes de la interrupción de estas actividades;

e) identifica el tiempo dentro del cual los impactos de no reanudar las actividades serían inaceptables a la organización;

NOTA: Esto puede denominarse período máximo tolerable de interrupción (MTPD).

f) establece plazos prioritarios dentro del tiempo identificado en e) anterior para reanudar las actividades interrumpidas a una capacidad mínima aceptable especificada;

NOTA: Esto puede denominarse objetivo de tiempo de recuperación (RTO).

g) utiliza los impactos comerciales para identificar actividades priorizadas;

h) determina qué recursos se necesitan para apoyar las actividades priorizadas;

i) determina las dependencias e interdependencias de las actividades priorizadas.

© ISO 2019 – Derechos reservados

NOTA: Los socios externos podrían considerarse de acuerdo con ISO 22318.

8.2.3 Evaluación de riesgos

La organización debe implementar y mantener un proceso de evaluación de riesgos sistemático.

NOTA Este proceso se puede realizar de acuerdo con ISO 31000.

La organización debe:

a) identificar los riesgos de interrupción de las actividades priorizadas de la organización y de su apoyo

b) recursos;

c) analizar sistemáticamente los riesgos de interrupción;

d) evaluar los riesgos de alteración que requieran tratamiento.

NOTA Los riesgos en esta sub-cláusula se relacionan con la interrupción del negocio. Riesgos y oportunidades relacionados con la eficacia del sistema de gestión se tratan en 6.1.

8.3 Estrategias y soluciones de continuidad del negocio

8.3.1 General

La organización debe identificar y seleccionar estrategias de continuidad del negocio basadas en los resultados del análisis de impacto empresarial y la evaluación de riesgos. Las estrategias de continuidad del negocio estarán compuestas por una o más soluciones.

8.3.2 Identificación y selección de estrategias y soluciones

La organización debe identificar y seleccionar las estrategias y soluciones adecuadas para la continuidad del negocio, teniendo en cuenta sus costos asociados para:

a) responder a las interrupciones;

b) continuar y recuperar las actividades priorizadas y sus recursos requeridos para cumplir con la entrega de productos y servicios a la capacidad acordada a lo largo del tiempo.

Para las actividades priorizadas, la organización debe identificar y seleccionar estrategias y soluciones considerando los objetivos de continuidad del negocio y la cantidad y el tipo de riesgo que la organización puede o no asumir que:

a) reducir la probabilidad de interrupciones;
b) acortar el período de interrupción;
c) limitar el impacto de la interrupción en los productos y servicios de la organización.

8.3.3 Requerimientos de recursos

La organización debe determinar los requisitos de recursos para implementar las soluciones de continuidad del negocio seleccionadas. Los tipos de recursos considerados incluirán pero no se limitarán a:

a) personas;
b) información y datos;
c) infraestructura física como edificios, lugares de trabajo u otras instalaciones y servicios públicos asociados;
d) equipos y consumibles;

© ISO 2019 – Derechos reservados

e) sistemas de tecnología de la información y las comunicaciones (TIC);
f) transporte;
g) finanzas;
h) socios y proveedores.

8.3.4 Implementación de soluciones

La organización debe implementar soluciones de continuidad del negocio seleccionadas para que puedan activarse cuando sea necesario.

8.4 Planes y procedimientos de continuidad del negocio

8.4.1 General

La organización debe implementar y mantener una estructura que permita la advertencia y la comunicación oportunas a las partes interesadas relevantes y proporcionar planes y procedimientos para administrar la organización durante una interrupción. Los planes y procedimientos se utilizarán cuando sea necesario para ejecutar soluciones de continuidad del negocio.
NOTA Existen diferentes tipos de procedimientos que comprenden los planes de continuidad del negocio.

Los procedimientos deberán:

a) sea específico con respecto a los pasos inmediatos que se deben tomar durante una interrupción;

b) ser flexible para responder a las cambiantes condiciones internas y externas de una interrupción;

c) centrarse en el impacto de los incidentes que potencialmente conducen a una interrupción;

d) ser eficaz para minimizar el impacto mediante la implementación de soluciones apropiadas;

e) asignar roles y responsabilidades para las tareas dentro de él.

8.4.2 Estructura de respuesta

La organización debe implementar y mantener una estructura que identifique uno o más equipos responsables para responder a las interrupciones.

Los roles y responsabilidades de cada equipo y las relaciones entre los equipos deben estar claramente establecidos.

En conjunto, los equipos estarán preparados para:

a) evaluar la naturaleza y el alcance de una interrupción y su impacto potencial;

b) evaluar el impacto frente a umbrales predefinidos que justifican el inicio de una respuesta formal;

c) activar una respuesta apropiada de continuidad del negocio;

d) planificar las acciones que deben emprenderse;

e) establecer prioridades (utilizando la seguridad humana como primera prioridad);

f) monitorear los efectos de la interrupción y la respuesta de la organización;

g) activar las soluciones de continuidad del negocio;

h) comunicarse con las partes interesadas pertinentes, las autoridades y los medios de comunicación.

Para cada equipo habrá:

a) personal identificado y sus asociados con la responsabilidad, autoridad y competencia necesarias

© ISO 2019 – Derechos reservados

para desempeñar su función designada;

b) procedimientos documentados para guiar sus acciones (ver 8.4.4) incluyendo aquellos para la activación, operación, coordinación y comunicación de la respuesta.

8.4.3 Advertencia y comunicación

8.4.3.1 La organización debe documentar y mantener procedimientos para:

a) comunicarse interna y externamente con las partes interesadas relevantes, incluyendo qué, cuándo, con quién y cómo comunicarse;

NOTA: La organización puede documentar y mantener procedimientos sobre cómo y bajo qué circunstancias la organización se comunica con los empleados y sus contactos de emergencia.

b) recibir, documentar y responder a las comunicaciones de las partes interesadas, incluido cualquier sistema de aviso de riesgos nacional o regional o equivalente;

c) garantizar la disponibilidad de los medios de comunicación durante una interrupción;

d) facilitar la comunicación estructurada con los servicios de emergencia;

e) detalles de la respuesta de la organización a los medios de comunicación después de un incidente, incluida una estrategia de comunicación;

f) registrar los detalles de la interrupción, las acciones y las decisiones tomadas.

8.4.3.2 Cuando sea aplicable, también se considerará e implementará lo siguiente:

a) alertar a las partes interesadas potencialmente afectadas por una interrupción real o inminente;

b) asegurar la adecuada coordinación y comunicación entre múltiples organizaciones de respuesta;

Los procedimientos de comunicación y advertencia se deben aplicar como parte del programa de ejercicios de la organización mencionado en 8.5.

8.4.4 Planes de continuidad del negocio

8.4.4.1 Los planes de continuidad del negocio deben proporcionar orientación e información que ayudarán a los equipos a responder a una interrupción y ayudarán a la organización con la respuesta yla recuperación.

En conjunto, los planes de continuidad del negocio deberán contener:

a) detalles de las acciones que los equipos tomarán para continuar o recuperar actividades priorizadas dentro de plazos predeterminados y monitorear los efectos de la interrupción y la respuesta de la organización a la misma;

b) referencia al umbral y proceso predefinidos para activar la respuesta;

c) procedimientos para permitir la entrega de productos y servicios a la capacidad acordada a las partes interesadas;

d) detalles para gestionar las consecuencias inmediatas de una interrupción teniendo debidamente en cuenta:

1) el bienestar de las personas;

2) prevención de una mayor pérdida o indisponibilidad de las actividades priorizadas;

3) protección del medio ambiente;

© ISO 2019 – Derechos reservados

e) un proceso para retirarse una vez finalizado el incidente.

8.4.4.2 Cada plan debe incluir:

a) propósito y alcance, y objetivos;

b) roles, responsabilidades del equipo que implementará el plan;

c) acciones y recursos para implementar las soluciones;

d) información de apoyo necesaria para activar (incluidos los criterios de activación), operar, coordinar y comunicar las acciones del equipo;

e) interdependencias internas y externas;

f) requisitos de recursos;

g) los requisitos de información.

Cada plan será utilizable y estará disponible en el momento y lugar en que se requiera.

8.4.5 Recuperación

La organización debe tener procesos documentados para restaurar y devolver las actividades comerciales de las medidas temporales adoptadas para respaldar los requisitos comerciales normales durante y después de una interrupción.

8.5 Programa de ejercicios

La organización debe implementar y mantener un programa de ejercicios y pruebas para validar con el tiempo la efectividad de sus estrategias y soluciones de continuidad del negocio.

La organización debe realizar ejercicios y pruebas que:

a) son consistentes con sus objetivos de continuidad del negocio;

b) se basan en escenarios apropiados que están bien planificados con metas y objetivos claramente definidos;

c) desarrollar el trabajo en equipo, la competencia, la confianza y el conocimiento para aquellos que tienen roles que desempeñar en relación con las interrupciones;

d) en conjunto a lo largo del tiempo, validar la totalidad de sus estrategias de continuidad del negocio;

e) producir informes posteriores al ejercicio formalizados que contengan resultados, recomendaciones y acciones para implementar mejoras;

f) se revisan en el contexto de promover la mejora continua;

g) se realizan a intervalos planificados y cuando hay cambios significativos dentro de la organización o el contexto en el que opera.

La organización debe actuar sobre los resultados de su ejercicio y prueba para implementar cambios y mejoras.

9 Evaluación de desempeño

9.1 Seguimiento, medición, análisis y evaluación

9.1.1 General

La organización debe determinar:

a) qué se necesita monitorear y medir;

b) los métodos de seguimiento, medición, análisis y evaluación, según corresponda, para asegurar resultados válidos;

c) cuando y quién debe realizar el seguimiento y la medición;

d) cuando y quién debe analizar y evaluar los resultados del seguimiento y la medición.

La organización debe conservar la información documentada apropiada como evidencia de los resultados. La organización debe evaluar el desempeño del BCMS y la efectividad del BCMS.

9.1.2 Evaluación de planes, procedimientos y capacidades de continuidad del negocio.

La organización debe evaluar la idoneidad, adecuación y eficacia de sus planes, procedimientos y capacidades de continuidad del negocio.

Estas evaluaciones se realizarán mediante revisiones periódicas, análisis, ejercicios, pruebas, post-incidente, informes y evaluaciones de desempeño.

La organización debe evaluar periódicamente el cumplimiento de los requisitos legales y reglamentarios aplicables, las mejores prácticas de la industria y el cumplimiento de su propia política y objetivos de continuidad del negocio.

La organización debe realizar evaluaciones a intervalos planificados después de un incidente o activación y cuando ocurran cambios significativos se actualizará de manera oportuna.

9.2 Auditoría interna

9.2.1 La organización debe realizar auditorías internas a intervalos planificados para proporcionar información sobre si el BCMS:

a) se ajusta a:

1) los propios requisitos de la organización para su BCMS,

2) los requisitos de este documento;

b) se implementa y mantiene de manera efectiva.

9.2.2 La organización debe:

a) planificar, establecer, implementar y mantener (un) programa (s) de auditoría, incluida la frecuencia, los métodos, las responsabilidades, los requisitos de planificación y los informes. El programa o programas de auditoría deberán tener en cuenta la importancia de los procesos en cuestión y los resultados de auditorías anteriores;

b) definir los criterios de auditoría y el alcance de cada auditoría;

c) seleccionar auditores y realizar auditorías para asegurar la objetividad y la imparcialidad del proceso de auditoría;

d) asegurarse de que los resultados de las auditorías se informen a la dirección pertinente;

e) conservar información documentada como evidencia de la implementación del programa de auditoría y los resultados de la auditoría.

9.3 Revisión de gestión

9.3.1 General

La alta dirección debe revisar el BCMS de la organización, a intervalos planificados, para asegurar su continuidad, idoneidad, adecuación y eficacia.

© ISO 2019 – Derechos reservados

9.3.2 Entrada de revisión por la dirección

La revisión por la dirección debe incluir la consideración de:

a) el estado de las acciones de las revisiones por la dirección anteriores;

b) cambios en asuntos externos e internos que son relevantes para el BCMS;

c) información sobre el desempeño de la continuidad del negocio, incluidas las tendencias en:

1) no conformidades y acciones correctivas;

2) seguimiento y medición de los resultados de la evaluación;

3) resultados de la auditoría;

d) comentarios de las partes interesadas;

e) la necesidad de cambios en el BCMS, incluida la política y los objetivos;

f) procedimientos y recursos que podrían utilizarse en la organización para mejorar el desempeño y la eficacia del BCMS;

g) información del BIA y evaluación de riesgos;

h) riesgos o cuestiones que no se abordan adecuadamente en ninguna evaluación de riesgos anterior;

i) resultados de ejercicios y pruebas;

j) lecciones aprendidas y acciones derivadas de cuasi accidentes e interrupciones;

k) oportunidades de mejora continua.

9.3.3 Salida de la revisión por la dirección

9.3.3.1 Los resultados de la revisión por la dirección deben incluir decisiones relacionadas con oportunidades de mejora continua y la posible necesidad de cambios en el BCMS para mejorar su eficiencia y eficacia e incluir lo siguiente:

a) variaciones del alcance del BCMS;

b) actualización del análisis de impacto comercial, evaluación de riesgos, estrategias y soluciones de continuidad comercial y planes de continuidad comercial;

c) modificación de procedimientos y controles para responder a problemas internos o externos que puedan afectar el BCMS;

d) cómo se medirá la eficacia de los controles.

9.3.3.2 La organización debe retener información documentada como evidencia de los resultados de las revisiones por la dirección y:

a) comunicar los resultados de la revisión por la dirección a las partes interesadas pertinentes;

b) tomar las medidas adecuadas en relación con esos resultados.

10 Mejora

10.1 No conformidad y acción correctiva

10.1.1.1 Cuando ocurre una no conformidad, la organización debe:

a) reaccionar ante la no conformidad y, según corresponda:

1) tomar medidas para controlarlo y corregirlo;

© ISO 2019 – Derechos reservados

2) lidiar con las consecuencias.

b) evaluar la necesidad de acción para eliminar las causas de la no conformidad a fin de que no se repita ni ocurra en otro lugar, mediante:

1) revisión de la no conformidad;

2) determinar las causas de la no conformidad;

3) determinar si existen no conformidades similares o si podrían ocurrir potencialmente;

c) implementar cualquier acción necesaria;

d) revisar la efectividad de cualquier acción correctiva tomada;

e) realizar cambios en el BCMS, si es necesario.

Las acciones correctivas deben ser apropiadas a los efectos de las no conformidades encontradas.

10.1.2 La organización debe retener información documentada como evidencia de:

a) la naturaleza de las no conformidades y cualquier acción posterior tomada;

b) los resultados de cualquier acción correctiva.

10.2 Mejora continua

La organización debe mejorar continuamente la idoneidad, adecuación o eficacia del BCMS.

La organización debe considerar los resultados del análisis y la evaluación, y los resultados de la revisión por la dirección, para determinar si hay necesidades u oportunidades que deben abordarse como parte de la mejora continua.

NOTA: La organización puede utilizar los procesos del BCMS tales como liderazgo, planificación y desempeño, evaluación, para lograr la mejora.

Bibliografía

[1] ISO 9001, *Sistemas de gestión de la calidad — Requisitos*

[2] ISO 14001, *Sistema de gestión ambiental — Requisitos con orientación para su uso*

[3] ISO 19011, *Directrices para auditar sistemas de gestión*

[4] ISO/IEC/TS 17021-6, *Evaluación de la conformidad — Requisitos para los organismos que realizan auditorías y certificaciones de sistemas de gestión — Parte 6: Requisitos de competencia para la auditoría y certificación de los sistemas de gestión de la continuidad del negocio*

[5] ISO/IEC 20000-1, *Tecnologías de la información — Gestión de servicios — Parte 1: Requisitos del sistema de gestión de servicios*

[6] ISO 22300, *Seguridad y resiliencia — Vocabulario*

[7] ISO/IEC 27001, *Tecnologías de la información — Técnicas de seguridad — Sistema de gestión de seguridad de la información — Requisitos*

[8] ISO/IEC 27031, *Tecnologías de la información — Técnicas de seguridad — Directrices para la preparación de la tecnología de la información y las comunicaciones para la continuidad del negocio*

[9] ISO 28000, *Especificación para sistemas de gestión de seguridad para la cadena de suministro*

[10] ISO 31000, *Gestión de riesgos — Guías*

[11] ISO/IEC 31010, *Gestión de riesgos — Técnicas de evaluación de riesgos*

[12] SI 24001, *Sistemas de gestión de seguridad y continuidad — Requisitos y orientación para su uso, Instituto de Normas de Israel*

[13] NFPA 1600, *Estándar sobre gestión de desastres / emergencias y programas de continuidad comercial, Asociación Nacional de Protección contra Incendios (USA)*

[14] Directriz para la redacción del plan de continuidad del negocio. Ministerio de Economía, Comercio e Industria, Japón, 2005

[15] Directriz de continuidad empresarial, *Consejo Central de Gestión de Desastres, Oficina del Gabinete, Gobierno de Japón, 2005*

[16] ANSI/ASIS SPC. – 2011, Auditoría de sistemas de gestión: Riesgo, *Resiliencia: Seguridad, y Continuidad*
–Guía de aplicación

[17] ANSI/ASIS/BSI BCM.01, *Sistema de gestión de continuidad del negocio: Requisitos y orientación para su uso*